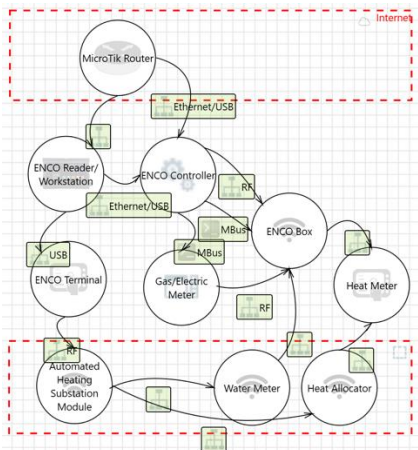


ASTRAL Example Pipeline



Data Flow Diagram (DFD)

Architectural Narrative

- Attacker or Attack-Capable Entities The diagram implies potential adversaries at multiple levels:
- External Attackers: Entities with network access to the system via exposed interfaces (e.g., internet-facing APIs, remote management ports, or cloud connections).
 - Internal Threat Actors: Authorized users (e.g., operators, maintenance personnel, or administrators) with direct or privileged access to HMI, engineering workstations, or field devices. Misconfigured roles or credential misuse are implicit risks.
 - Physical Intruders: Entities with direct access to field-level devices (e.g., tampering with sensors, actuators, or local control panels).
 - Compromised Components: Devices or systems within the architecture that, if breached (e.g., a router or HMI), could pivot to other assets (e.g., lateral movement from IT to OT).
- Key Components
- Field Level (Purdue Level 0-1):
 - Sensors: Temperature, flow, or pressure sensors transmitting analog/digital signals to controllers.
 - Actuators: Valves, pumps, or heating elements receiving control commands from PLCs/RTUs.
 - Local Controllers: PLCs (Programmable Logic Controllers) or RTUs (Remote Terminal Units) executing ladder logic or control algorithms.
 - IoT Gateways: Edge devices aggregating sensor data and translating protocols (e.g., Modbus to MQTT).
 - Control Level (Purdue Level 2):
 - SCADA/HMI Workstations: Human-machine interfaces for operator monitoring and manual override.
 - Histarians: Databases storing time-series data (e.g., temperature logs, actuator states).
 - Engineering Workstations: Used for PLC programming, firmware updates, or configuration changes.
 - Site/Operations Level (Purdue Level 3):
 - Site Supervisory Systems: Centralized control servers coordinating multiple PLCs or subsystems.
 - Firewalls/DMZs: Network security appliances segmenting IT/OT traffic.
 - Enterprise Level (Purdue Level 4-5):
 - Enterprise IT Systems: ERP, CMMS (Computerized Maintenance Management Systems), or cloud platforms for analytics/remote monitoring.
 - Remote Access Gateways: VPN concentrators or jump servers for off-site maintenance.
 - Network Infrastructure:
 - Industrial Switches/Routers: Connecting field devices to control networks (e.g., Ethernet/IP, PROFIBUS).

Architectural Reconstruction

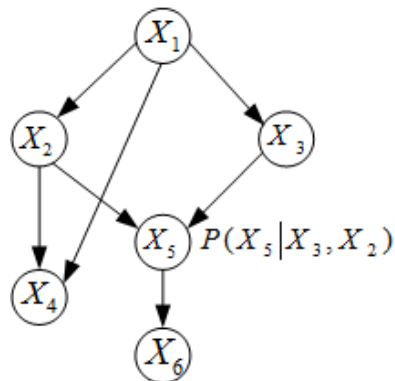
Threat Model

Threat Type	Scenario	Potential Impact
Tampering	An attacker with physical access to the field devices (e.g., sensors or actuators) could tamper with their hardware or firmware to manipulate temperature readings or control signals. For example, by exploiting unprotected JTAG ports or unencrypted firmware updates, the attacker could alter the reported temperature values or override control commands, causing the heating system to operate outside safe parameters. This could lead to overheating, equipment damage, or even fire hazards. (CVE-2023-31996, a vulnerability in firmware update mechanisms, has been observed in attacks like 'FrostyGeop').	Overheating of the system, equipment damage, or fire hazards due to incorrect temperature readings or control signals.
Denial of Service	An attacker could launch a DoS attack on the central controller by flooding it with malicious network traffic, exploiting vulnerabilities in the communication protocol (e.g., Modbus/TCP). For instance, sending a high volume of requests to the controller could overwhelm its processing capability, leading to system unresponsiveness. This could disrupt the heating system's operation, causing discomfort or, in critical environments like hospitals, endangering patients. (CVE-2018-10635, a vulnerability in Modbus/TCP implementations, has been exploited in attacks like 'BlackEnergy').	Disruption of heating system operation, leading to discomfort or endangering patients in critical environments.
Elevation of Privilege	An attacker with access to the maintenance interface could exploit weak authentication mechanisms to elevate their privileges. For example, default or easily guessable credentials could allow the attacker to gain administrative access to the central controller. With elevated privileges, the attacker could modify system configurations, disable safety controls, or issue unauthorized commands, potentially causing physical damage or safety incidents. (CVE-2023-7921, a vulnerability in authentication mechanisms, has been observed in attacks like 'Trisix').	Unauthorized modifications to system configurations, disabling of safety controls, or issuance of unauthorized commands, leading to physical damage or safety incidents.

Threat Modelling (STRIDE-LM)



Attack Modelling (Attack Tree)



Bayesian Network Model Representation

Countermeasure Portfolio



Countermeasure Portfolio Simulation



Probabilistic Risk Analysis

Enter system installation date	01/01/2024
Load Model Attributes	
Asset Attributes	
Asset ID	Asset Name
[U01] Attacker	Attacker
[A01] Building Management System (BMS) Protocols (Modbus, BACnet, OPC UA)	Building Management System (BMS) Protocols
[A02] Engineering Workstation (PLC Programming, HMI Configuration)	Engineering Workstation (PLC Programming, HMI Configuration)
[A03] PLC Firmware/Logic (Ladder Logic, Control Algorithms)	PLC Firmware/Logic (Ladder Logic, Control Algorithms)
[A04] Safety Instrumented Systems (SIS) or Interlocks	Safety Instrumented Systems (SIS) or Interlocks
[A05] SCADA/HMI Audit Logs (Operator Actions, System Events)	SCADA/HMI Audit Logs (Operator Actions, System Events)
[A06] Historian Database (Time-Series Operational Data)	Historian Database (Time-Series Operational Data)
[A07] Heating System Web Interface (Configuration, Monitoring)	Heating System Web Interface (Configuration, Monitoring)
[A08] Enterprise Integration Points (APIs, Gateways)	Enterprise Integration Points (APIs, Gateways)
[A09] Network Infrastructure (Switches, Routers, Firewalls)	Network Infrastructure (Switches, Routers, Firewalls)

Vulnerability Attributes

Asset ID	Asset Name
[V01] Weak or Missing Authentication in BMS Protocols	Weak or Missing Authentication in BMS Protocols
[V02] Modbus TCP/RTU Lacking Authentication (Default Configuration)	Modbus TCP/RTU Lacking Authentication (Default Configuration)
[V03] BACnet Broadcast Messages Vulnerable to Spoofing (Who-Is, I-Am)	BACnet Broadcast Messages Vulnerable to Spoofing (Who-Is, I-Am)
[V04] OPC UA Misconfigured Certificates or Disabled Encryption	OPC UA Misconfigured Certificates or Disabled Encryption
[V05] Exploit CVE-2022-3028 (BMS Protocol Vulnerability)	Exploit CVE-2022-3028 (BMS Protocol Vulnerability)
[V06] Weak Access Controls on Engineering Workstations (Default/Shared Credentials)	Weak Access Controls on Engineering Workstations (Default/Shared Credentials)
[V07] Exploit CVE-2023-22893 (Control Logic Vulnerability)	Exploit CVE-2023-22893 (Control Logic Vulnerability)
[V08] Unauthenticated Firmware Update Mechanism	Unauthenticated Firmware Update Mechanism
[V09] Insecure Log Storage (Unencrypted, Writable by Low-Privilege Users)	Insecure Log Storage (Unencrypted, Writable by Low-Privilege Users)
[V10] Excessive Permissions on Historian (Read/Write for Non-Admin Users)	Excessive Permissions on Historian (Read/Write for Non-Admin Users)

```
Generated AutomationML File

<?xml version="1.0" encoding="utf-8"?>
<CAEXFile SchemaVersion="3.0" FileName="cps.xml" xmlns:xsi="http://www.w3.org/2001
  <InstanceHierarchy Name="CPS_Assets">
    <Version1.0/Version>
      <!-- Users/Attackers -->
      <InternalElement Name="Attacker" ID="[U01] Attacker" RefBaseSystemIDPath="As
        <Attribute Name="HumanErrorEstimationPercentage" AttributeDataType="xs:stri
          <Value>100/Value>
        </Attribute>
      </InternalElement>
      <!-- Assets -->
      <InternalElement Name="Building Management System (BMS) Protocols (Modbus, BAC
        <Attribute Name="AutomationEquipment" AttributeDataType="xs:string" RefAttr
          <Value>BMS-001/Value>
        </Attribute>
        <Attribute Name="Vendor" AttributeDataType="xs:string">
          <Value>BMS-001/Value>
        </Attribute>
        <Attribute Name="Part" AttributeDataType="xs:string">
          <Value>BMS-001/Value>
        </Attribute>
        <Attribute Name="Version" AttributeDataType="xs:string">
          <Value>1.0/Value>
        </Attribute>
        <Attribute Name="FailureRatePerHour" AttributeDataType="xs:float">
          <Value>0.0001/Value>
        </Attribute>
        <Attribute Name="Impact Rating" AttributeDataType="xs:float">
          <Value>9.2/Value>
        </Attribute>
        <Attribute Name="Date of first use" AttributeDataType="xs:string">
          <Value>2020-01-01/Value>
        </Attribute>
      </InternalElement>
      <ExternalInterface Name="BMS_Protocols_Interface" ID="[A01] BMS_Protocols_Ext
        <ExternalInterface Name="ModbusTCP" RefBaseClassPath="AutomationMLInterfa
        <ExternalInterface Name="BACnet" RefBaseClassPath="AutomationMLInterface1
        <ExternalInterface Name="OPCUA" RefBaseClassPath="AutomationMLInterfaceCl
      </ExternalInterface>
    </InstanceHierarchy>
```

AutomationML (XML) Representation